CompanySync

Pre-Launch Audit Report

Prepared July 22, 2026 • Target launch: August 1, 2026

Executive Summary

A full audit was run across four areas: security, speed/performance, cost efficiency, and unfinished work. The platform is in good shape for an August 1 launch — no show-stoppers were found. Core protections (tenant data isolation, payment webhook verification, subscription/billing guard rails, support-session lockdown) are in place and verified in enforcement mode in production.

The audit identified 4 URGENT items (complete before launch), 4 HIGH items (launch week), and a set of MEDIUM/LOW items for the first 30 days after launch. The urgent items total roughly 2–3 working days; the high items roughly 3–4 more. This puts the full pre-launch list comfortably inside the August 1 window.

Security	**GOOD**	Core protections verified; package updates + 2 tightenings needed
Speed	**NEEDS WORK**	One large download on first load; dashboard over-fetches data
Cost efficiency	**FAIR**	Limits in place but fail open; storm AI feature needs a cap
Completeness	**GOOD**	Two known gaps, one blocked on an outside vendor

URGENT — Complete before launch (est. 2–3 days total)

1. Update 10 outdated software packages

Ten of the app's underlying packages (including axios, lodash, nodemailer, ws, undici, vite, form-data) have publicly known security weaknesses rated High. Safe updated versions exist for all ten. This is the single most important security task: these are the first thing automated scanners look for once the product is public.

Estimated effort: Half a day (update + full regression test run)

2. Add the missing production database index

The development database has a stronger combined index on the main data table (entity type + company) than production, which only indexes by company. Because both use the same index name, production silently kept the weaker version. As customer data grows, common lookups (settings, API keys, daily usage) will slow down noticeably. The fix is one safe SQL statement.

Estimated effort: 1–2 hours (including verification)

3. Verify identity on the voice-assistant connection

The live voice-assistant connection currently trusts the company ID sent by the browser instead of confirming it against the logged-in session. This should be verified server-side so one account can never open a connection under another company's identity or spend another company's AI credits.

Estimated effort: Half a day (dev + prod must both be updated and tested)

4. Cross-check company membership on AI billing requests

The main AI request handler accepts a company ID in the request body and uses it for billing and usage limits. It should confirm the requesting user actually belongs to that company — the same check pattern already used elsewhere in the app.

Estimated effort: Half a day

HIGH — Launch week (est. 3–4 days total)

5. Split the app into on-demand page downloads

All 200+ pages currently ship as one large download before the dashboard can appear. Loading each page only when it's opened will dramatically improve first-load speed — especially on phones in the field, which is where your customers live. This is the single biggest speed win available.

Estimated effort: 1–2 days (mechanical change + thorough click-through test)

6. Stop the Dashboard from loading 8,000 records

On open, the Dashboard requests up to 1,000 records each from eight different lists (invoices, customers, estimates, proposals, projects, leads, tasks, payments). It should request pre-computed summaries instead. Today it feels fine with small data; at a few thousand records per company it will visibly lag.

Estimated effort: 1 day

7. Cap the storm-alert AI lead generator

When a storm is detected, the system automatically runs an AI lead-generation job for every subscribed company in the affected area. One large storm across a big metro could trigger hundreds of paid AI calls at once. Recommend a per-storm cap and/or making this feature opt-in per company.

Estimated effort: Half a day

8. Tighten "fail open" usage limits for expensive operations

If the database hiccups while checking a customer's daily AI/SMS/email limit, the system currently allows the action through unmetered (a deliberate choice so paying customers are never blocked by a glitch). For the most expensive operations (AI analysis, voice calls), a short retry before allowing would keep costs predictable without hurting customers.

Estimated effort: Half a day

MEDIUM — First 30 days after launch

9. Reduce background page polling

A few pages (voice workspace, inspections, admin dashboard) re-check the server every 10–30 seconds even when idle. Cheap today, but multiplies directly with user count. Recommend slowing intervals and pausing when the browser tab is hidden.

10. Cap unbounded data queries

Some reporting endpoints (e.g. rep performance) load every lead, customer, and invoice for a company with no upper limit. Add sensible caps or move the math into the database.

11. Fix the AI assistant's record-counting tool

The assistant's "count all records" tool downloads entire tables (up to 10,000 full records each across 7 types) just to count them. A count query returns the same answer at a fraction of the cost.

12. Decide on access rules for uploaded files

Uploaded files (photos, documents) are reachable by anyone who has the exact link. Links are random and unguessable — a common and generally accepted practice — but for sensitive documents (contracts, insurance paperwork) consider requiring a login to view.

13. Finish the Reports "Export to PDF" feature

Marked as a to-do in the code. Either finish it before launch or hide the button via the hidden-features registry so customers don't click a dead end.

14. Re-run the two security scanners that crashed

Of three automated scanners, the dependency scanner completed (its findings are item 1). The static-code and privacy-flow scanners crashed mid-run due to a tooling problem — worth re-running for a clean bill of health. Manual review covered the same ground.

LOW / EXTERNAL — Monitor

15. ABC Supply ordering (blocked on vendor)

The material-ordering integration is built but waiting on production API keys from ABC Supply. Nothing to do on our side except follow up with them.

16. Very long lead lists render slowly

The Leads page renders every lead in a neighborhood group at once. Above ~1,000 leads in one view the browser will stutter. List virtualization solves this when the time comes.

17. Review leftover internal defaults

A hardcoded internal notification email and master-company IDs exist in the code. They function as intended (platform-owner notifications), but confirm they're the addresses you want receiving alerts at launch.

VERIFIED SOLID — No action needed

- Tenant data isolation is ON in full enforcement mode in production (TENANT_GUARD_MODE=enforce), covering all entity reads and writes in both dev and prod.
- Twilio (calls/SMS) and Stripe (payments) webhooks both verify cryptographic signatures before acting.
- Support-session impersonation is locked down: read-only functions only, full audit logging, 30-minute expiry, owner email notification.
- Subscription, trial, and billing-credit fields cannot be self-granted through the data API — verified by 5 automated guard test suites that run on every code push.
- Live smoke tests pass: onboarding/trial flow (26 checks), request size limits + webhook URL safety (23 checks), trial daily limits (25 checks), quick-create shortcuts (24 checks).
- Duplicate-payment protections: 77 automated tests passing.

FALSE ALARMS — Investigated and cleared

- "Several app pages would fail in production" — incorrect. The flagged routes (dashboard, reports, sync, presence, rep performance, QuickBooks callback, recording playback) all exist in the production server; the first scan simply looked in the wrong file.
- "Outsiders can trigger SMS/email sends through the function API" — not substantiated. No such directly-callable send functions are registered, and sampled handlers verify the caller's login and company membership individually. (A full sweep of all 211 functions is still recommended — see item 4.)

- "Tenant protection defaults to log-only" — true of the code default, but the production deployment explicitly sets full enforcement.

SUGGESTED TIMELINE TO AUGUST 1

July 22–23 — URGENT items 1–2: package updates + database index (quick, safe, biggest risk reduction)

July 23–24 — URGENT items 3–4: identity checks on voice connection + AI billing requests

July 25–28 — HIGH items 5–6: on-demand page loading + dashboard summary queries

July 29 — HIGH items 7–8: storm AI cap + usage-limit tightening

July 30 — Full regression: all automated test suites + manual click-through of core flows

July 31 — Republish to production, verify health checks, final smoke test on the live site

Aug 1 — Launch. MEDIUM items begin as post-launch work.

Methodology: four parallel deep code audits (security & tenant isolation, cost efficiency, performance, launch readiness), a production-dependency security scan (npm audit), production deployment log review, and manual verification of every critical finding against the live codebase and deployment configuration. Automated test status at time of writing: 175+ checks passing across 6 suites.